Relatório de Perícia de Rede — Parte 2 (VaxGuard Connect / BioFrio)

Item	Valor
Projeto	VaxGuard Connect — SENAI Dev Experience Módulo B 2026, Parte 2
Arquivo analisado	`captura_biofrio_2026.pcap` (3.611 bytes, formato pcap/libpcap, encapsulamento **Raw IPv4** — não há cabeçalho Ethernet)
SHA-256	`84a6420637ceb2be688c55fe74a1df5c15e144168861337e9f6b99ee4dfdf29f`
Ferramenta	TShark (Wireshark) **4.6.8** (v4.6.8-0-ge677bf052328) + capinfos
Fuso horário	Sistema em `E. South America Standard Time` = **UTC-3 (Brasília)**. Todos os horários abaixo estão em UTC-3, formato "Data e hora do dia" (`tshark -t ad`). Conferência: frame 24 tem `frame.time_epoch = 1792516470` = 17:14:30 UTC = **14:14:30 UTC-3**.

Nos comandos abaixo: `T="C:\Program Files\Wireshark\tshark.exe"` e `P=captura_biofrio_2026.pcap`.

1. Visão geral da captura

Comando: `capinfos P` e `tshark -r P -qz conv,ip -qz conv,tcp -qz io,phs`

- **28 pacotes**, de **20/10/2026 14:10:00,000** a **20/10/2026 14:16:05,000** (365 s).
- Todos são IPv4 / TCP. Protocolos de aplicação: **HTTP** (2 frames) e **MQTT** (17 frames); o resto são handshakes TCP.

Host	Papel (deduzido dos pacotes)
192.168.20.10	Servidor central: HTTP na porta 80 e broker MQTT na porta 1883
192.168.20.31	Dispositivo da câmara (Client ID `vaxguard-cam03`, `device":"VG-CAM03"`). O login HTTP no painel também saiu deste IP
192.168.20.66	Host desconhecido — só aparece para publicar o comando suspeito

Conversa TCP	Frames	Início	O que é
192.168.20.31:49210 ↔ 192.168.20.10:80	5	14:10:00	Login HTTP no painel
192.168.20.31:51544 ↔ 192.168.20.10:1883	19	14:10:01	Sessão MQTT do dispositivo
192.168.20.66:44120 ↔ 192.168.20.10:1883	4	14:14:29	Publicação do comando suspeito

2. Questão 1 — Reconhecimento do dispositivo

Filtro: `mqtt.topic contains "/telemetria"` → frames 13–20 e 26–28. Exemplo: **frame 13** (14:10:05).

Comando:

```
tshark -r P -Y "mqtt.topic contains \"/telemetria\"" -T fields -e frame.number -e ip.version -e ip.src -e ip.dst -e tcp.dstport -e mqtt.topic -e mqtt.msg
```

Campo	Resposta	Evidência
IP do dispositivo / versão	**192.168.20.31 / IPv4**	frame 13, `ip.src`, `ip.version = 4`
IP do broker / versão	**192.168.20.10 / IPv4**	frame 13, `ip.dst`
Protocolo de aplicação	**MQTT v3.1.1** (MQ Telemetry Transport) sobre TCP	frame 9 (Connect: `Version: MQTT v3.1.1 (4)`), frame 13 = `Publish Message`
Porta de destino (broker)	**TCP 1883** (MQTT sem TLS)	frame 13, `tcp.dstport = 1883`
Campo "placa" do JSON	**ESP32**	payload do frame 13
Tópico MQTT	**biofrio/cam03/telemetria**	frame 13, `mqtt.topic`

Payload do frame 13 (o `mqtt.msg` vem em hexadecimal; decodificado):

```
{"device":"VG-CAM03","placa":"ESP32","seq":100,"temp":4.8,"umid":58,"porta":"FECHADA","estado":"NORMAL"}
```

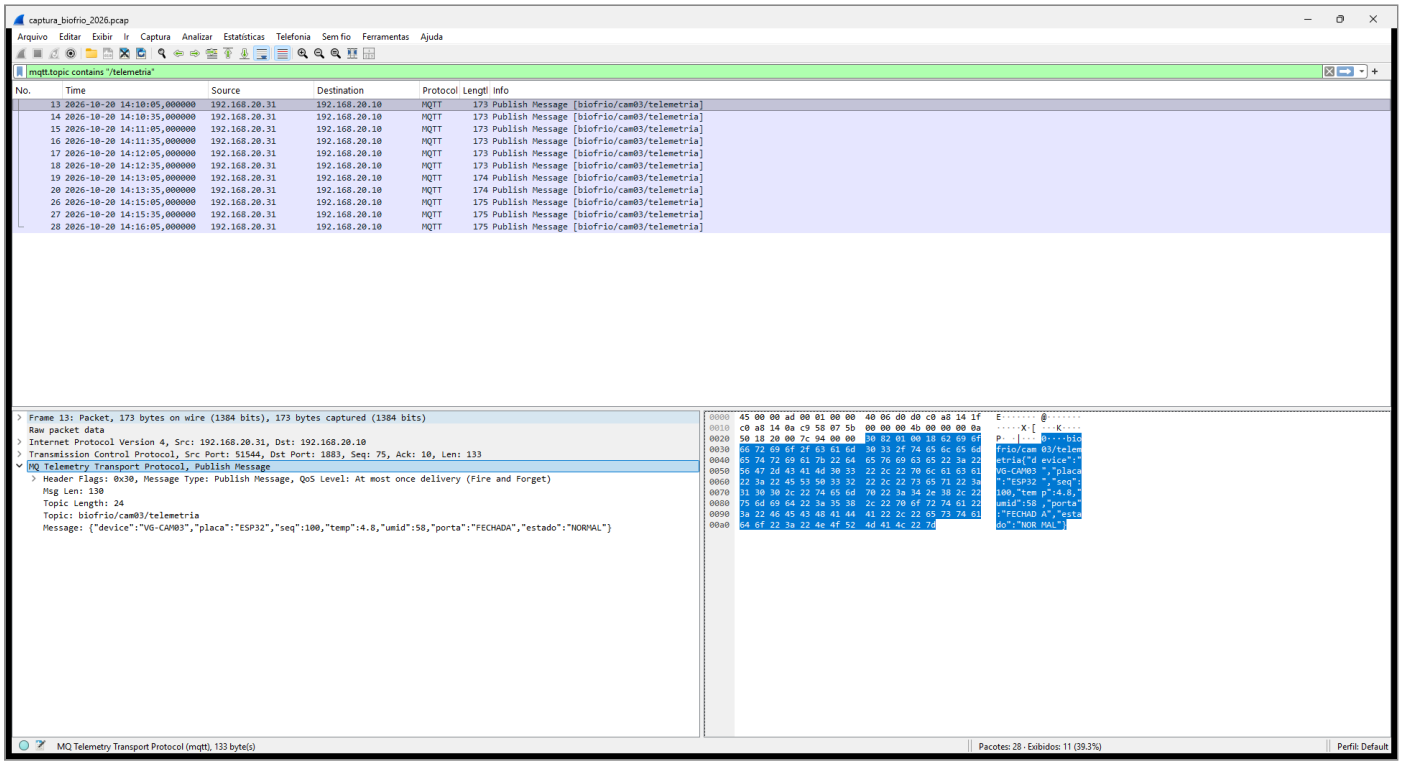


Figura 1 — Questão 1 — telemetria do dispositivo (IP, porta 1883, tópico, JSON com "placa":"ESP32")
Filtro de exibição: `mqtt.topic contains "/telemetria"` · Frame selecionado: **13** · Tempo: Data e hora do dia (UTC-3) · Arquivo: prints/q1_telemetria.png

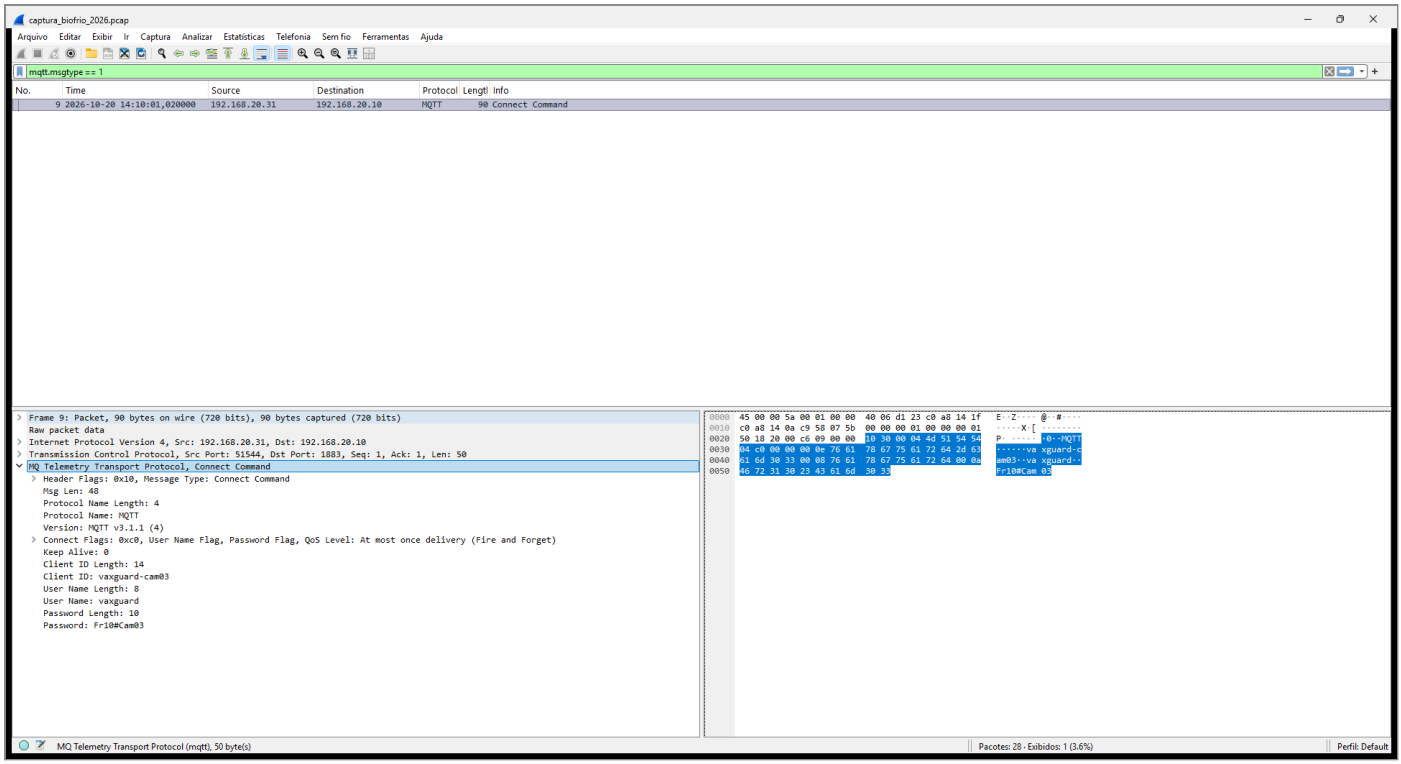


Figura 2 — Questão 1 — versão do protocolo (MQTT v3.1.1)
Filtro de exibição: `mqtt.msgtype == 1` · Frame selecionado: **9** · Tempo: Data e hora do dia (UTC-3) · Arquivo: prints/q1_q2d_mqtt_connect.png

3. Questão 2 — Credenciais em texto claro

Comando: `tshark -r P -qz follow,tcp,ascii,0` (fluxo HTTP) e `tshark -r P -V -Y "mqtt.msgtype==1"` (MQTT Connect).

Fluxo 0 (frames 4 e 5), extraído literalmente:

```
POST /painel/login HTTP/1.1
Host: 192.168.20.10
User-Agent: VaxGuard-Painel/1.0
Content-Type: application/x-www-form-urlencoded
Content-Length: 45

usuario=tecnico.cam03&senha=Vac%40BioFrio2026

HTTP/1.1 302 Found
Server: Werkzeug/3.0 Python/3.11
Location: /painel/cam03
Set-Cookie: session=c6a1f09b7d2e4418; Path=/
```

a) Usuário: **`tecnico.cam03`** — frame 4 (14:10:00,120), 192.168.20.31 → 192.168.20.10:80, filtro `http.request.method == "POST"`, campo *HTML Form URL Encoded → usuario*.

b) Senha: **`Vac@BioFrio2026`**. No pacote ela aparece como `Vac%40BioFrio2026` porque o formulário é enviado em `application/x-www-form-urlencoded`: caracteres especiais são trocados por `%` + código hexadecimal ASCII. `0x40` = 64 = **`@`**. Ou seja, `%40` não é parte da senha; é só a forma codificada do `@`. (O Wireshark já mostra o valor decodificado no painel de detalhes, em *HTML Form URL Encoded*.)

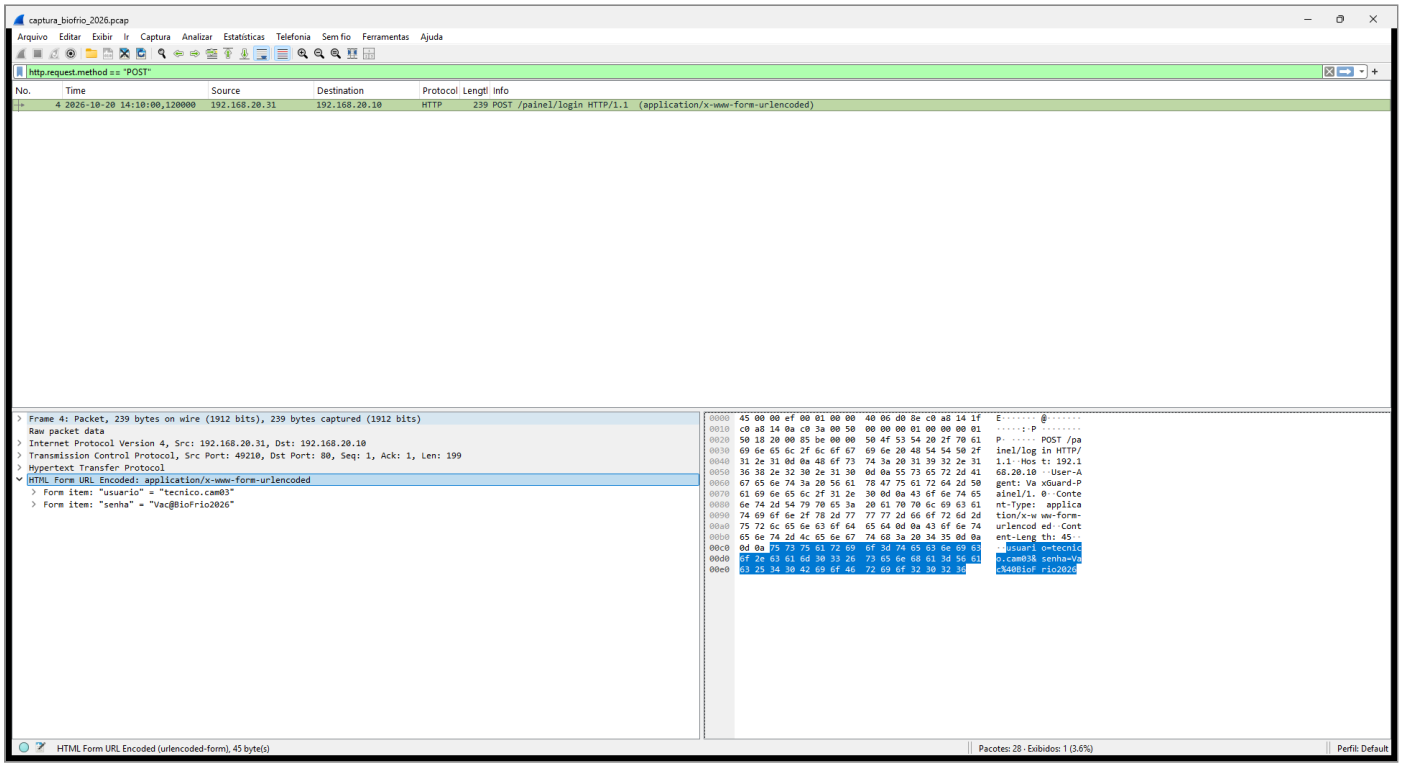


Figura 3 — Questão 2 a/b — login HTTP em texto claro (usuario / senha)
Filtro de exibição: `http.request.method == "POST"` · Frame selecionado: **4** · Tempo: Data e hora do dia (UTC-3) · Arquivo: prints/q2ab_login_http.png

c) Cookie de sessão: **`session=c6a1f09b7d2e4418`** — frame 5 (14:10:00,180), resposta `302 Found` de 192.168.20.10, cabeçalho `Set-Cookie`. Filtro: `http.set_cookie`.

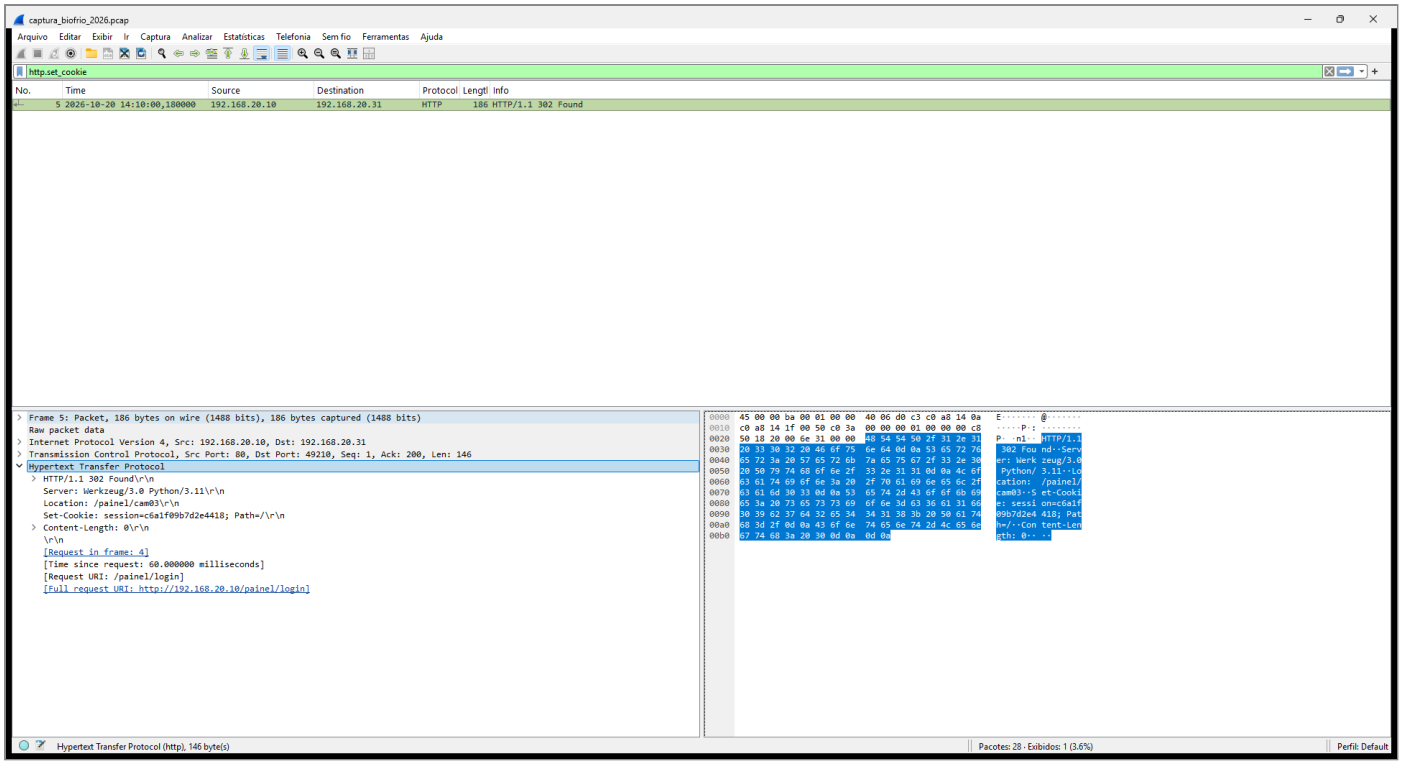


Figura 4 — Questão 2 c — Set-Cookie da sessão
Filtro de exibição: `http.set_cookie` · Frame selecionado: **5** · Tempo: Data e hora do dia (UTC-3) · Arquivo: prints/q2c_set_cookie.png

d) Credenciais MQTT do dispositivo — frame 9 (14:10:01,020), 192.168.20.31 → 192.168.20.10:1883, *Connect Command*, filtro `mqtt.msgtype == 1`:

- Client ID: `vaxguard-cam03`
- Usuário: **`vaxguard`**
- Senha: **`Fr10#Cam03`**
- O broker aceitou: frame 10, *Connect Ack*, `mqtt.conack.val == 0` (Connection Accepted).

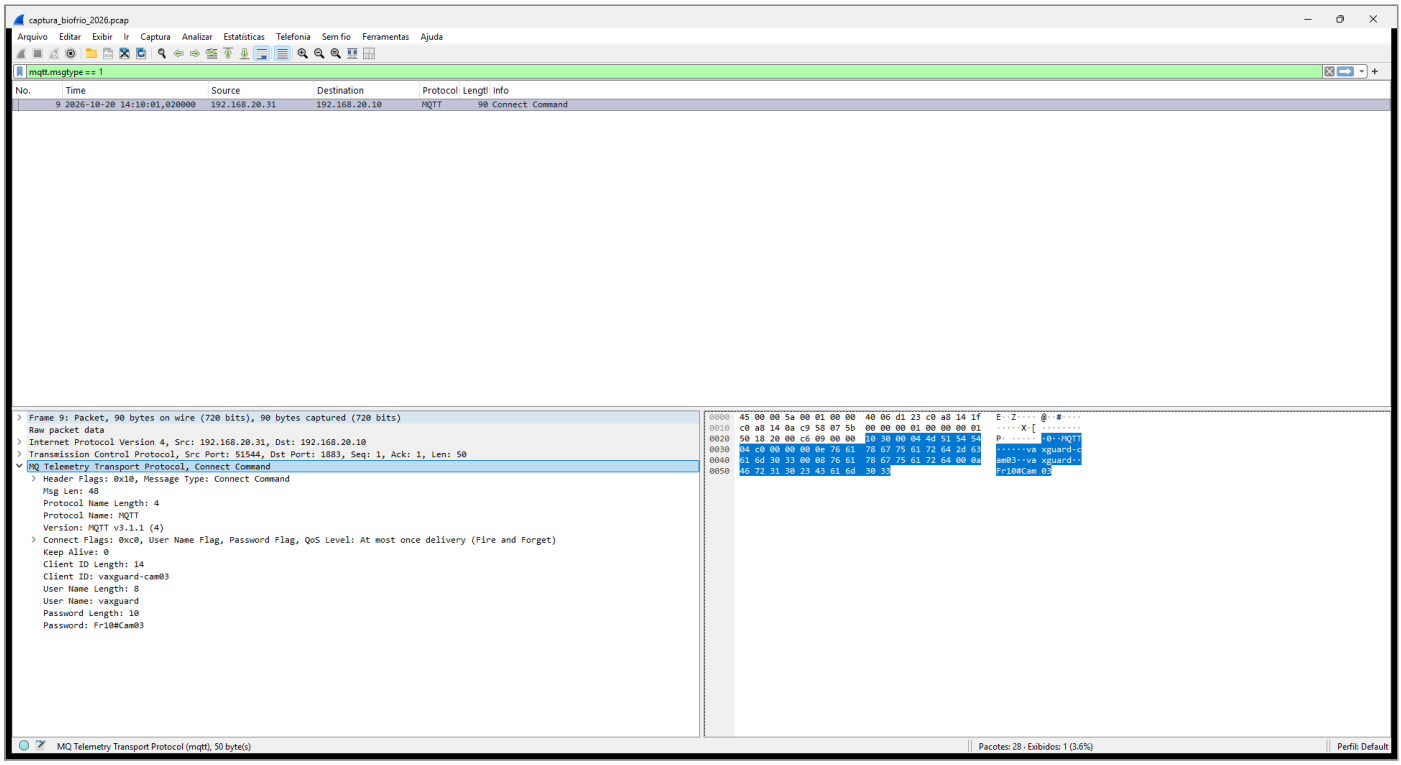


Figura 5 — Questão 2 d — credenciais MQTT no Connect (User Name / Password)
Filtro de exibição: `mqtt.msgtype == 1` · Frame selecionado: **9** · Tempo: Data e hora do dia (UTC-3) · Arquivo: prints/q1_q2d_mqtt_connect.png

e) Falha: **ausência de criptografia no transporte** (HTTP na porta 80 e MQTT na porta 1883, ambos sem TLS). Qualquer pessoa na mesma rede que capture o tráfego lê usuário, senha e cookie — e com o cookie pode até sequestrar a sessão do painel sem saber a senha. Correções:

1. Painel só em **HTTPS** (TLS), redirecionando a porta 80 para 443, com HSTS; cookie com `Secure; HttpOnly; SameSite`.
2. MQTT sobre **TLS (porta 8883)**, de preferência com certificado de cliente por dispositivo (mTLS).
3. Trocar as senhas expostas (`tecnico.cam03` e `vaxguard`), usar credenciais únicas por dispositivo e invalidar a sessão `c6a1f09b7d2e4418`.
4. Segmentar a rede (VLAN só para os dispositivos IoT e o servidor).

4. Questão 3 — Comando suspeito no broker

Filtro: `mqtt.topic == "biofrio/cam03/cmd"` → frames 11 (Subscribe), 24 e 25.

Comandos:

```
tshark -r P -Y "mqtt.topic == \"biofrio/cam03/cmd\"" -T fields -e frame.number -e ip.src -e ip.dst -e tcp.srcpo
rt -e tcp.dstport -e mqtt.msgtype -e mqtt.msg
tshark -r P -qz follow,tcp,ascii,2
```

a) Quem publicou: **192.168.20.66** (porta 44120 → 192.168.20.10:1883), **frame 24, 20/10/2026 14:14:30,000**. Conteúdo:

```
{"cmd":"VENTILACAO_OFF","cmd_id":"x90"}
```

Ou seja, um comando para **desligar a ventilação** da câmara CAM03.

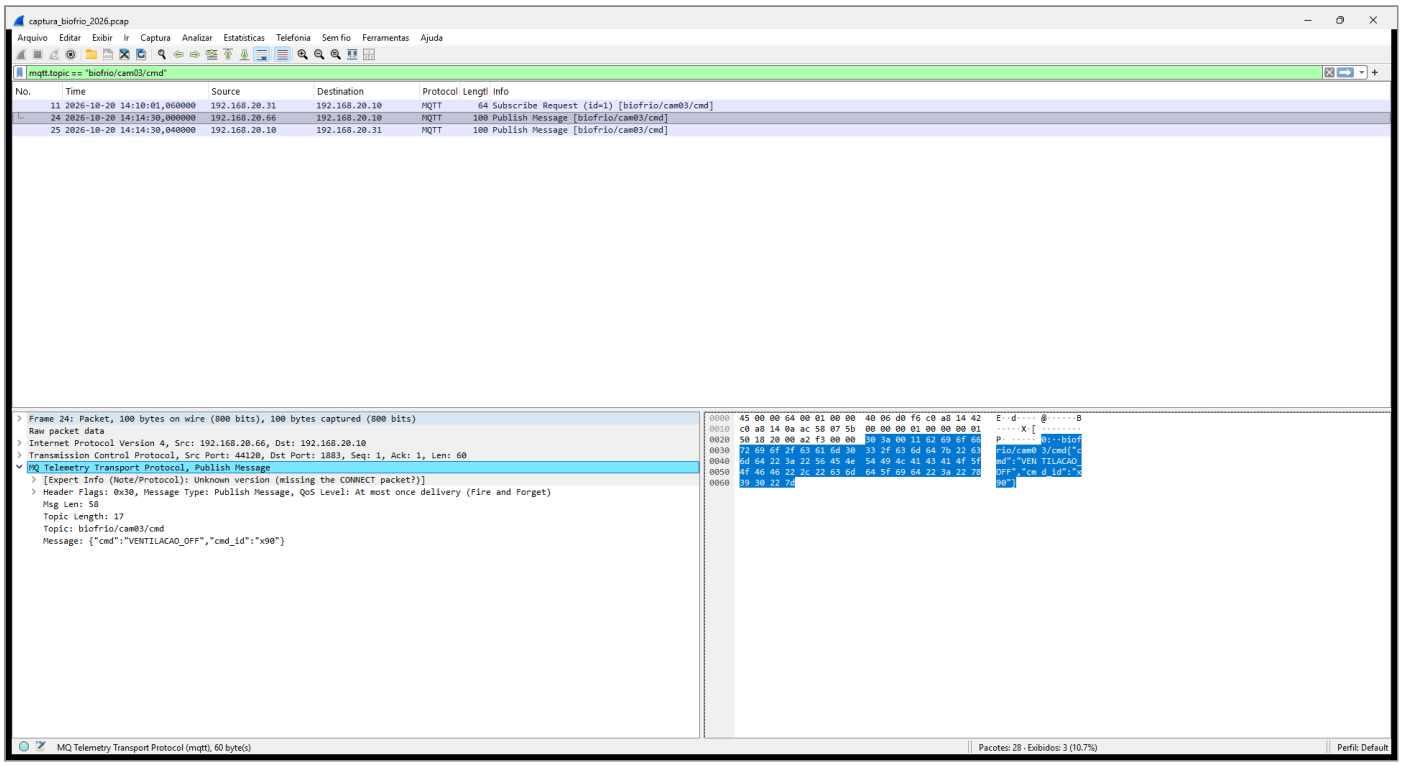


Figura 6 — Questão 3 a/b — Publish VENTILACAO_OFF vindo de 192.168.20.66
Filtro de exibição: `mqtt.topic == "biofrio/cam03/cmd"` · Frame selecionado: **24** · Tempo: Data e hora do dia (UTC-3) · Arquivo: prints/q3ab_comando_malicioso.png

b) Não é o servidor autorizado. A origem do frame 24 é `192.168.20.66`, enquanto todas as respostas legítimas do sistema vêm de `192.168.20.10`: o `302 Found` do login (frame 5), o `Connect Ack` (frame 10), o `Subscribe Ack` (frame 12) e o próprio repasse do comando (frame 25). O host .66 não aparece em nenhum outro momento da captura. Detalhe importante (`follow,tcp,ascii,2` e frames 21–24): o .66 abriu o TCP e **mandou o Publish direto, sem nenhum pacote MQTT Connect** — não houve usuário/senha nem Connect Ack nessa conexão, e mesmo assim o broker aceitou a mensagem.

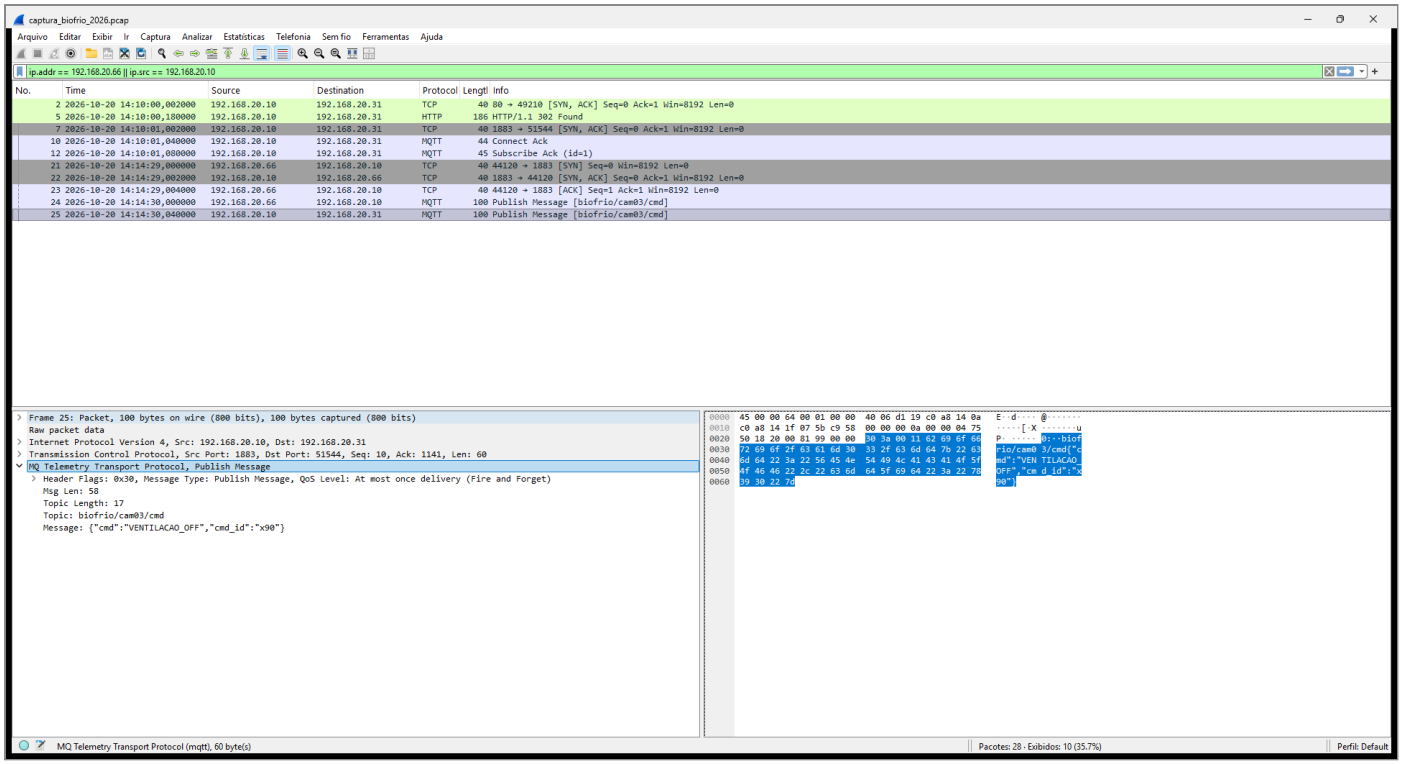


Figura 7 — Questão 3 b — respostas legítimas vêm de .10; conexão do .66 (21–24) sem Connect
Filtro de exibição: `ip.addr == 192.168.20.66 || ip.src == 192.168.20.10` · Frame selecionado: **25** · Tempo: Data e hora do dia (UTC-3) · Arquivo: prints/q3b_comparacao_origens.png

c) Sim, o dispositivo estava inscrito. Frame 11 (14:10:01,060): 192.168.20.31 envia *Subscribe Request (id=1)* para o tópico `biofrio/cam03/cmd`; o broker confirma no frame 12 (*Subscribe Ack*). Por isso, quando o .66 publicou nesse tópico, o broker — que só faz o papel de "carteiro" e não verifica quem publicou — **repassou a mensagem a todos os inscritos**: frame 25 (14:14:30,040, 40 ms depois), 192.168.20.10:1883 → 192.168.20.31:51544, mesmo payload `VENTILACAO_OFF`, `x90`.

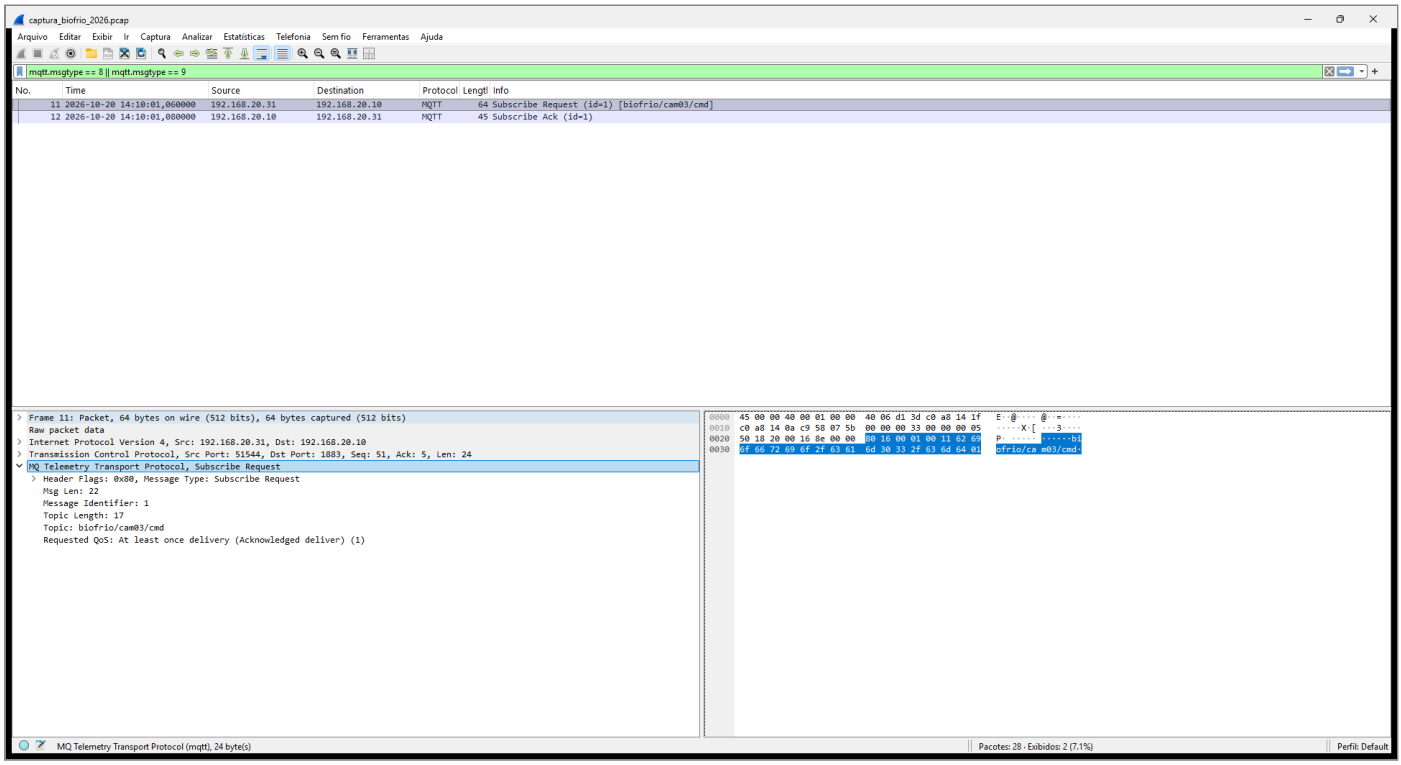


Figura 8 — Questão 3 c — Subscribe do dispositivo em biofrio/cam03/cmd
Filtro de exibição: `mqtt.msgtype == 8 || mqtt.msgtype == 9` · Frame selecionado: **11** · Tempo: Data e hora do dia (UTC-3) · Arquivo: prints/q3c_subscribe.png

d) Telemetria antes e depois (comando de `tshark` da Questão 1, payload decodificado):

Frame	Horário (UTC-3)	seq	temp (°C)	estado
13	14:10:05	100	4,8	NORMAL
14	14:10:35	101	5,0	NORMAL
15	14:11:05	102	5,3	NORMAL
16	14:11:35	103	6,1	NORMAL
17	14:12:05	104	6,9	NORMAL
18	14:12:35	105	7,8	NORMAL
19	14:13:05	106	8,6	**ATENCAO**
20	14:13:35	107	9,2	ATENCAO
24/25	**14:14:30**	—	—	**comando VENTILACAO_OFF**
26	14:15:05	108	10,4	**CRITICO**
27	14:15:35	109	11,9	CRITICO
28	14:16:05	110	13,5	CRITICO

A temperatura **já vinha subindo** antes do comando (4,8 → 9,2 °C, cerca de +0,2 a +0,9 °C a cada 30 s, já em ATENCAO desde 14:13:05). Depois do `VENTILACAO_OFF` ela **acelera** (+1,5 e +1,6 °C a cada 30 s), passa de 10 °C e o estado vira **CRITICO** na primeira leitura seguinte. A porta continua `FECHADA` em todas as leituras, então abertura de porta não explica o aquecimento. Efeito provável: com a ventilação desligada, o ar frio deixou de circular e a excursão térmica se agravou rapidamente.

Observação: entre 14:13:35 (seq 107) e 14:15:05 (seq 108) não há leituras às 14:14:05 e 14:14:35, embora o `seq` seja contínuo. A captura não mostra o motivo.

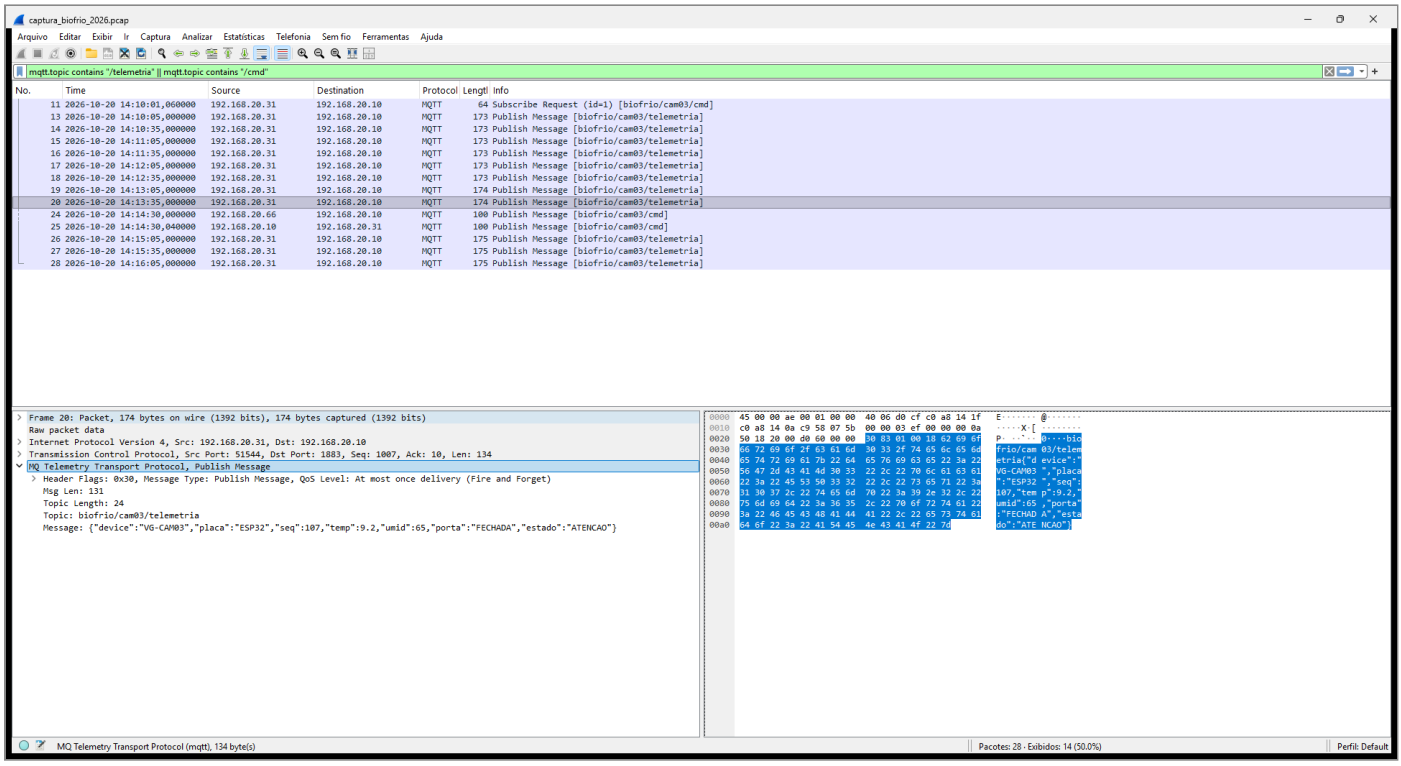


Figura 9 — Questão 3 d — última leitura antes do comando: 9.2 °C, ATENCAO
Filtro de exibição: `mqtt.topic contains "/telemetria" || mqtt.topic contains "/cmd"` · Frame selecionado: **20** · Tempo: Data e hora do dia (UTC-3) · Arquivo: prints/q3d_frame20_atencao.png

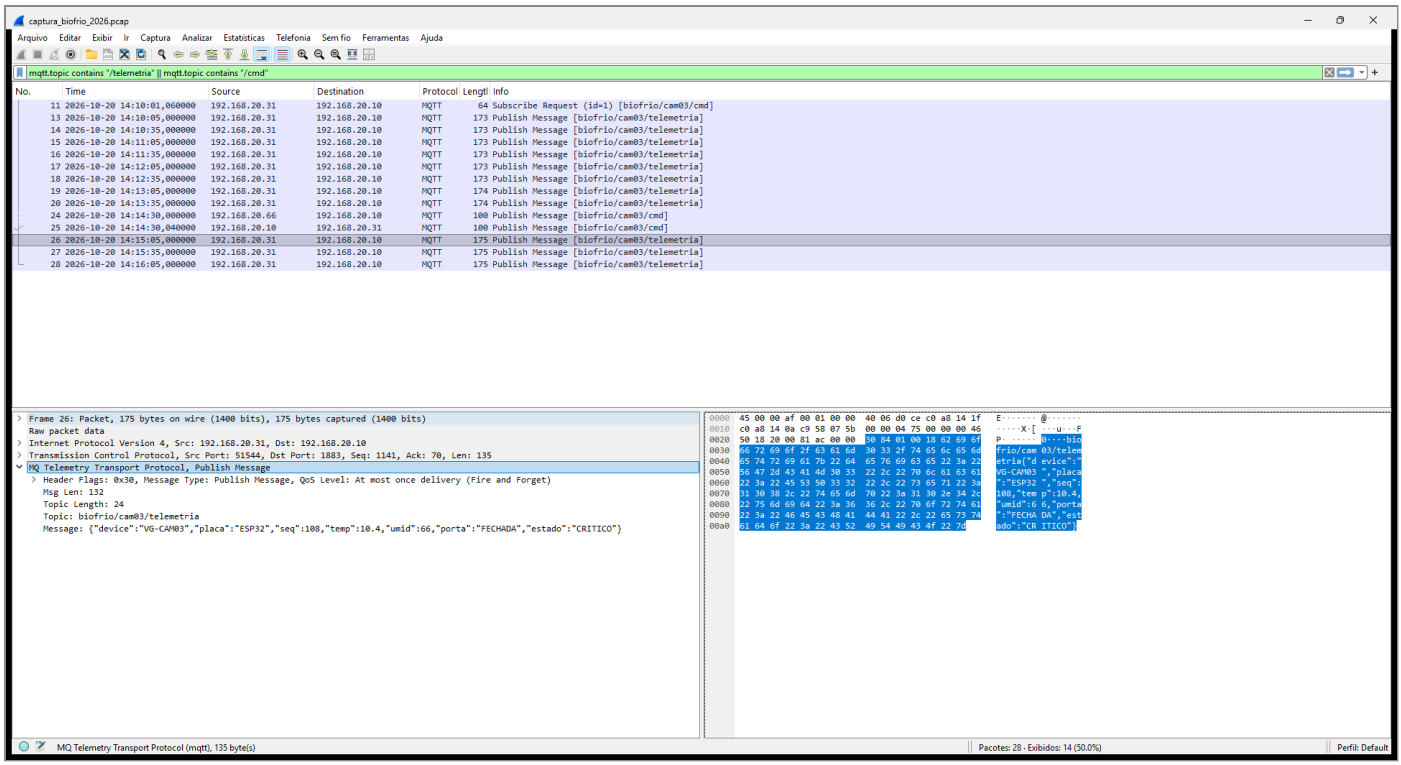


Figura 10 — Questão 3 d — primeira leitura após o comando: 10.4 °C, CRITICO
Filtro de exibição: `mqtt.topic contains "/telemetria" || mqtt.topic contains "/cmd"` · Frame selecionado: **26** · Tempo: Data e hora do dia (UTC-3) · Arquivo: prints/q3d_frame26_critico.png

e) Mecanismos de segurança ausentes (qualquer um impediria o ataque):

1. **Autenticação obrigatória no broker** — o .66 publicou sem nem enviar `CONNECT` com usuário/senha (`allow_anonymous false`, e de preferência certificado de cliente/mTLS).
2. **Controle de acesso por tópico (ACL)** — só o servidor 192.168.20.10/backend deveria poder publicar em `biofrio/cam03/cmd`; o dispositivo só deveria publicar em `.../telemetria`.
3. **Autenticação/assinatura das mensagens de comando** — ex.: HMAC ou assinatura com chave secreta + `cmd_id`/timestamp anti-replay; o ESP32 rejeitaria comandos sem assinatura válida.
4. (Complementar) Firewall/segmentação: só IPs autorizados alcançando a porta do broker.

5. Questão 4 — Linha do tempo e recomendações

a) Linha do tempo (20/10/2026, UTC-3)

Comando: `tshark -r P -t ad`

Horário	Frame(s)	Evento
14:10:00,120	4	Login no painel: `POST /painel/login` de 192.168.20.31 com `usuario=tecnico.cam03`, senha em texto claro
14:10:00,180	5	Servidor responde `302 Found` e entrega o cookie `session=c6a1f09b7d2e4418`
14:10:01,020	9–10	Dispositivo VG-CAM03 conecta ao broker MQTT (usuário `vaxguard`, senha `Fr10#Cam03`); conexão aceita
14:10:01,060	11–12	Dispositivo se inscreve em `biofrio/cam03/cmd`
14:10:05	13	Primeira telemetria: 4,8 °C, NORMAL
14:10:35 – 14:12:35	14–18	Temperatura sobe de 5,0 para 7,8 °C, ainda NORMAL
14:13:05	19	8,6 °C — estado passa para **ATENCAO**
14:13:35	20	9,2 °C, ATENCAO
14:14:29	21–23	Host desconhecido **192.168.20.66** abre conexão TCP com o broker (1883)
14:14:30,000	24	192.168.20.66 publica `{"cmd":"VENTILACAO_OFF","cmd_id":"x90"}` em `biofrio/cam03/cmd`, **sem MQTT Connect/autenticação**
14:14:30,040	25	Broker repassa o comando ao dispositivo 192.168.20.31
14:15:05	26	10,4 °C — estado **CRITICO**
14:15:35	27	11,9 °C, CRITICO
14:16:05	28	**13,5 °C, CRITICO — última leitura crítica da captura**

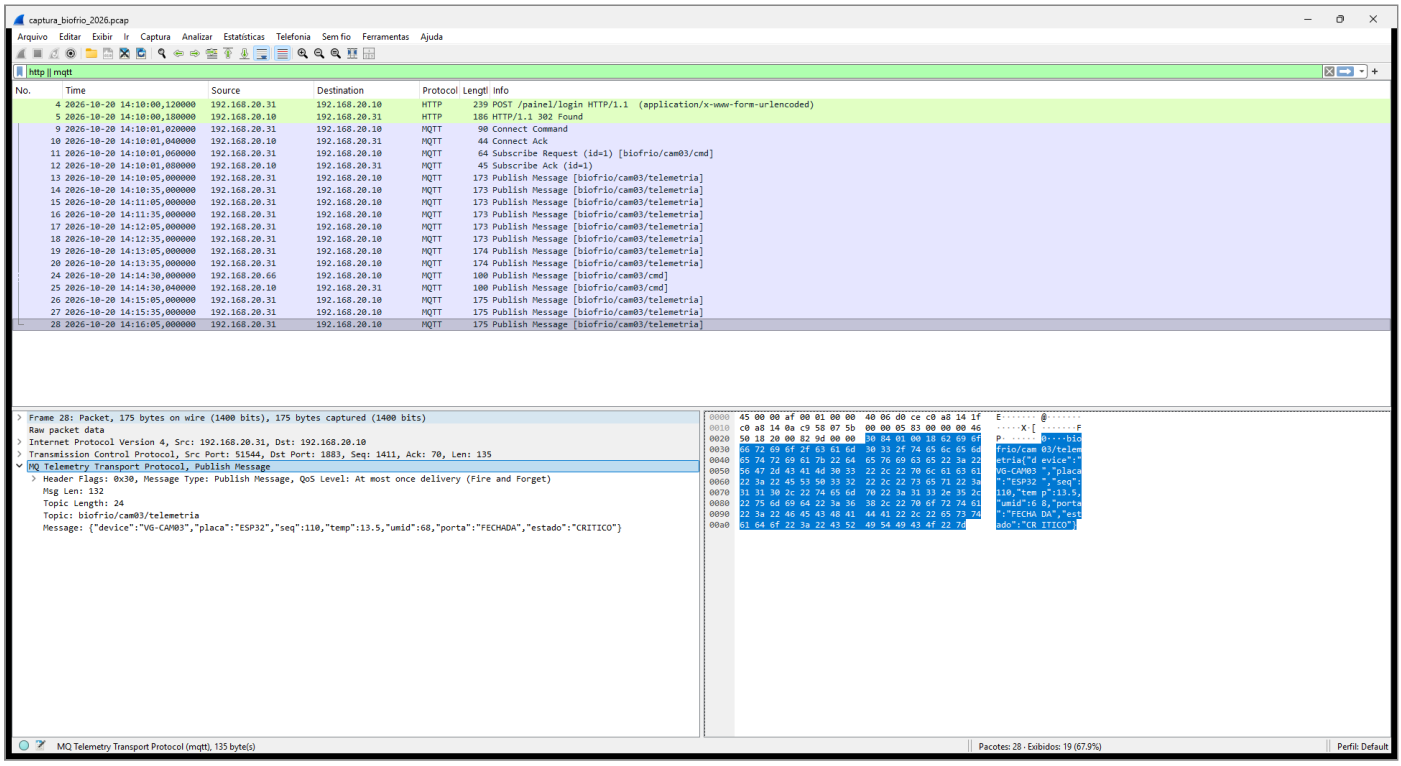


Figura 11 — Questão 4 a — linha do tempo completa; última leitura crítica (13.5 °C)
Filtro de exibição: `http || mqtt` · Frame selecionado: **28** · Tempo: Data e hora do dia (UTC-3) · Arquivo: prints/q4_linha_do_tempo.png

b) Classificação

Ação maliciosa (comando não autorizado / injeção de comando MQTT). Fundamentação:

- O comando `VENTILACAO_OFF` (frame 24) veio de **192.168.20.66**, que não é o servidor (192.168.20.10) nem o dispositivo, e não aparece em mais nenhum tráfego legítimo.
- Ele publicou **sem se autenticar** (nenhum `CONNECT` nos frames 21–24), aproveitando o broker aberto.
- Foi enviado justamente quando a câmara já estava em ATENCAO, e logo depois a temperatura disparou para CRITICO.
- Não é erro de operação: o técnico logado (`tecnico.cam03`) usou o IP .31, e não há nenhuma requisição HTTP ao painel gerando o comando; o comando não passou pelo servidor de aplicação.

Ressalva honesta: a temperatura já subia antes das 14:14:30 com a porta fechada, então pode ter havido também um problema de refrigeração anterior — a captura não mostra a causa dessa primeira subida. Mas o agravamento para CRITICO coincide com o comando malicioso, por isso **não foi apenas uma falha do compressor**.

c) Três medidas técnicas

1. **Criptografia de transporte:** HTTPS (TLS 1.2+) no painel e MQTT sobre TLS na porta 8883; desativar as portas 80 (exceto redirecionamento) e 1883. Assim uma nova captura mostraria apenas tráfego cifrado, sem senhas nem cookies.
2. **Autenticação das mensagens de comando:** cada comando assinado pelo servidor (HMAC-SHA256 com chave secreta por dispositivo, ou assinatura digital), contendo `cmd_id` único e timestamp; o ESP32 descarta comandos sem assinatura válida, repetidos ou antigos.
3. **Controle de acesso ao broker:** desabilitar acesso anônimo, credenciais/certificados únicos por dispositivo, e ACL por tópico (somente o backend publica em `biofrio/+/cmd`; cada dispositivo só publica na própria `.../telemetria` e só assina o próprio `.../cmd`). Complementar com firewall/VLAN liberando a porta do broker apenas aos IPs autorizados, e logs/alertas de conexões de IPs desconhecidos.

6. Conclusão

A captura mostra que (1) o painel web e o broker MQTT trafegam **sem criptografia**, expondo a senha do técnico (`tecnico.cam03` / `Vac@BioFrio2026`), o cookie de sessão e a credencial MQTT do dispositivo (`vaxguard` / `Fr10#Cam03`); e (2) às **14:14:30 de 20/10/2026 (UTC-3)** um host não autorizado, **192.168.20.66**, publicou sem autenticação o comando `VENTILACAO_OFF` no tópico de comandos da CAM03. O broker repassou o comando ao dispositivo inscrito, e a câmara passou de ATENCAO (9,2 °C) para **CRITICO**, chegando a **13,5 °C** às 14:16:05. O incidente é classificado como **ação maliciosa** que agravou uma excursão já em curso; não foi apenas falha do compressor. As correções prioritárias são TLS no HTTP e no MQTT, autenticação obrigatória + ACL no broker, e assinatura dos comandos enviados aos dispositivos.

Apêndice — Roteiro das capturas de tela

Prints reais do Wireshark 4.6.8 (GUI), abertos com `Wireshark.exe -r captura_biofrio_2026.pcap -Y <filtro> -g <frame> -t ad` (perfil de configuração temporário, preferência `mqtt.show_msg_as_text:TRUE`), janela maximizada e capturada; a camada de aplicação (MQTT / HTTP / HTML Form URL Encoded) foi expandida no painel de detalhes. Os itens "Seguir > Fluxo TCP" e "Estatísticas > Conversações" (alternativo/opcional) não foram capturados; o conteúdo equivalente está nos fluxos transcritos nas seções 3 e 4.

Questão	Filtro de exibição	Frame a selecionar	O que expandir/destacar no painel de detalhes
Q1	`mqtt.topic contains "/telemetria"`	13	*Internet Protocol Version 4* (Version 4, Src 192.168.20.31, Dst 192.168.20.10); *TCP* (Dst Port 1883); *MQ Telemetry Transport* → Topic `biofrio/cam03/telemetria` e Message (para ver o JSON com `"placa":"ESP32"`, clicar com o botão direito no campo Message → *Copiar* → *...como texto ASCII*, ou ver no painel de bytes)
Q1 (versão MQTT)	`mqtt.msgtype == 1`	9	*MQ Telemetry Transport* → `Version: MQTT v3.1.1 (4)`
Q2 a/b	`http.request.method == "POST"`	4	*HTML Form URL Encoded* → `usuario` = tecnico.cam03 e `senha` = Vac@BioFrio2026 (painel de bytes mostra `Vac%40...`)
Q2 c	`http.set_cookie`	5	*Hypertext Transfer Protocol* → `Set-Cookie: session=c6a1f09b7d2e4418`
Q2 d	`mqtt.msgtype == 1`	9	*MQ Telemetry Transport* → `User Name: vaxguard`, `Password: Fr10#Cam03`
Q2 (alternativa)	—	4	Botão direito → *Seguir* > *Fluxo TCP* mostra login + cookie numa só tela
Q3 a/b	`mqtt.topic == "biofrio/cam03/cmd"`	24	*IPv4* → Src **192.168.20.66**; *MQTT* → Topic `biofrio/cam03/cmd`, Message `{"cmd":"VENTILACAO_OFF","cmd_id":"x90"}`
Q3 b (comparação)	`ip.addr == 192.168.20.66 || ip.src == 192.168.20.10`	25 (e 24)	Mostrar que respostas legítimas (frames 5, 10, 12, 25) vêm de 192.168.20.10 e que a conexão do .66 (frames 21–24) não tem Connect
Q3 c	`mqtt.msgtype == 8 || mqtt.msgtype == 9`	11	*MQTT* → Subscribe Request, Topic `biofrio/cam03/cmd`; depois frame 25 (repasse ao 192.168.20.31)
Q3 d	`mqtt.topic contains "/telemetria" || mqtt.topic contains "/cmd"`	20 e 26	Message: `temp 9.2 / ATENCAO` (frame 20) vs. `temp 10.4 / CRITICO` (frame 26)
Q4 a	`http || mqtt`	28	Lista completa com a coluna de horário; destacar frame 28 (última leitura CRÍTICA, 13.5 °C)
Q4 (opcional)	—	—	*Estatísticas* > *Conversações* > *IPv4* mostrando os dois clientes (.31 e .66)